Requirement checklists

Oct 30, 2026

One tickable line per legal requirement of Regulation (EU) 2024/2847, with its article reference and the evidence to hold. Tick a line only against a pointer to that evidence. Run the first checklist per product; the rest follow from the role and class it records. Article wording was read via legal mirrors; verify quotations against the OJ text before relying on them in a filing.

1. Scope, role and route gate (per product)

Record every answer with its basis. The class and role recorded here decide which of the later checklists apply.

- [ ] Product boundary fixed: the hardware, the software needed to use it, and manufacturer-built remote data processing count as one product (Art 3(1)-(2)); modules sold or licensed separately are listed as their own products
- [ ] The three scope conditions tested and recorded: a product with digital elements; made available on the EU market in a commercial activity; an intended or reasonably foreseeable direct or indirect, logical or physical data connection (Art 2(1); Art 3(1), (22))
- [ ] Exclusions checked: MDR and IVDR devices, vehicles under Regulation 2019/2144 and Delegated Regulation 2025/1535, EASA-certified aviation products, marine equipment, identical-specification spare parts, products exclusively for national security, defence or classified information (Art 2(2)-(7))
- [ ] Placing on the market decided per unit, and per version for standalone software; internal-use and not-yet-supplied software recorded as not placed (Art 3(21)-(22); Art 4)
- [ ] Economic-operator role fixed per product and market: manufacturer, authorised representative, importer, distributor or open-source steward (Art 3(13)-(17); Arts 18-24)
- [ ] Own-brand, white-label, integration and substantial-modification triggers checked for becoming the manufacturer (Arts 21-22)
- [ ] Free and open-source determination made: unmonetised and outside the CRA, steward, or manufacturer (Art 3(22); Art 24; guidance C(2026) 5252 Section 3)
- [ ] Core functionality stated once, from instructions, marketing and technical documentation, and compared with the 26 technical descriptions in Implementing Regulation (EU) 2025/2392 (Art 7(1); Art 8(1))

- [ ] Class recorded with rationale: default, important Class I, important Class II or critical (Annexes III and IV)
- [ ] Conformity route chosen under Art 32: Module A, B+C, H or certification; Class I plans for B+C or H while no harmonised standard is cited
- [ ] High-risk AI overlay checked: deemed compliance and the applicable assessment route (Art 12)
- [ ] Tailor-made status and any explicitly agreed derogation documented (Annex I Part I 2(b); Part II point 8; Recital 64)
- [ ] Legacy status recorded: units placed before 11 Dec 2027 are caught only on substantial modification, but Art 14 applies to all of them (Art 69(2)-(3))
- [ ] Support period set from expected use, user expectations, product nature and Union law, at least five years unless expected use is shorter (Art 13(8))

2. Annex I Part I: essential requirements for product properties

Point 1 is absolute. Points 2(a) to 2(m) apply on the basis of the Art 13(2) risk assessment, so each is ticked either as implemented or as not applicable with a written justification (Art 13(3)-(4)).

- [ ] Point 1: designed, developed and produced to ensure an appropriate level of cybersecurity based on the risks. Evidence: secure-development process description, threat model, risk assessment with per-item applicability
- [ ] 2(a): made available without known exploitable vulnerabilities. Evidence: release scan against EUVD, CVE/NVD and the CISA KEV catalogue; patch status; documented mitigations for anything unpatched
- [ ] 2(b): secure by default configuration, including the possibility to reset the product to its original state; any tailor-made derogation agreed in writing. Evidence: default-configuration export, no default credentials, optional services off, reset test
- [ ] 2(c): vulnerabilities addressable through security updates; where applicable, automatic security updates installed by default with a clear opt-out, user notification and postponement. Evidence: update design note, signature and anti-rollback tests, opt-out evidence, Recital 56 justification where automatic install is not default
- [ ] 2(d): protection from unauthorised access by appropriate control mechanisms, including authentication, identity or access management, and reporting of possible unauthorised access. Evidence: access model, MFA for privileged roles, lockout, intrusion alerting, negative tests
- [ ] 2(e): confidentiality of stored, transmitted or otherwise processed data, such as by encrypting relevant data at rest or in transit. Evidence: cryptographic inventory, protocol configuration, key management design, downgrade tests

- [ ] 2(f): integrity of stored, transmitted or otherwise processed data, commands, programs and configuration against unauthorised manipulation, and reporting of corruption. Evidence: verified boot, signed software and configuration, integrity monitoring tests
- [ ] 2(g): processing of only data that are adequate, relevant and limited to what is necessary for the intended purpose. Evidence: data inventory per function, telemetry defaults, retention schedule
- [ ] 2(h): availability of essential and basic functions, also after an incident, including resilience and mitigation measures against denial-of-service attacks. Evidence: essential-function list, rate limiting, degradation and recovery tests
- [ ] 2(i): minimised negative impact on the availability of services provided by other devices or networks. Evidence: emitter inventory, egress controls, no amplification behaviour
- [ ] 2(j): limited attack surfaces, including external interfaces. Evidence: interface inventory per operating state, port scans, debug ports disabled or protected
- [ ] 2(k): reduced impact of an incident using appropriate exploitation mitigation mechanisms and techniques. Evidence: hardened build flags, sandboxing, privilege separation, fuzzing results
- [ ] 2(l): recording and monitoring of relevant internal activity, including access to or modification of data, services or functions, with an opt-out mechanism for the user. Evidence: event catalogue, sample logs, opt-out mechanism
- [ ] 2(m): users can securely and easily remove all data and settings on a permanent basis, and transfer them securely to another product where such transfer is possible. Evidence: erase test per data type, export test
- [ ] Cross-check: every item marked not applicable has a clear justification in the technical documentation, and residual risk is treated by other means (Art 13(4); Recital 55)
- [ ] Cross-check: Annex I is applied to the manufacturer's own remote data processing where a product function depends on it (Art 3(2); Recitals 11-12)

3. Annex I Part II: vulnerability handling requirements

All eight apply to every manufacturer, when placing the product on the market and throughout the support period (Art 13(8)). None is risk-qualified.

- [ ] Point 1: vulnerabilities and components identified and documented, including a software bill of materials in a commonly used and machine-readable format covering at least the top-level dependencies. Evidence: SBOM per release in the technical file, vulnerability register

- [ ] Point 2: vulnerabilities addressed and remediated without delay in relation to the risks posed, including by providing security updates; security updates separated from functionality updates where technically feasible. Evidence: triage SLAs, release records, justification for any bundling
- [ ] Point 3: effective and regular tests and reviews of the security of the product. Evidence: test plan, reports, threat-driven re-test triggers
- [ ] Point 4: once a security update is available, information about fixed vulnerabilities shared and publicly disclosed: description, affected products, impact, severity, remediation; any delay justified in the duly justified cases allowed. Evidence: advisory index, machine-readable advisories, delay decisions
- [ ] Point 5: a policy on coordinated vulnerability disclosure put in place and enforced. Evidence: published CVD policy, PSIRT procedure, enforcement records
- [ ] Point 6: sharing of information about potential vulnerabilities facilitated, including in third-party components, with a contact address for reporting. Evidence: security.txt, published contact address, intake records, upstream-sharing records
- [ ] Point 7: mechanisms to securely distribute updates so that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, automatically. Evidence: signing, verification before install, anti-rollback, recovery
- [ ] Point 8: security updates disseminated without delay and, unless otherwise agreed for a tailor-made product, free of charge, accompanied by advisory messages. Evidence: publication records, advisories, pricing policy
- [ ] Cross-check: each security update stays available for at least 10 years or the remaining support period (Art 13(9)); public archives of earlier versions carry risk warnings (Art 13(11))

4. Article 13: manufacturer obligations

One line per paragraph. Paragraph numbering follows the OJ text as reproduced by legal mirrors and cross-checked against the Commission FAQ and guidance.

- [ ] 13(1): the product is designed, developed and produced in accordance with Annex I Part I
- [ ] 13(2): a cybersecurity risk assessment is undertaken and its outcome applied in planning, design, development, production, delivery and maintenance
- [ ] 13(3): the risk assessment is documented and updated as appropriate during the support period, and states whether and how each Annex I Part I point 2 requirement applies
- [ ] 13(4): the risk assessment is included in the technical documentation, with a justification for each requirement not applied

- [ ] 13(5): due diligence is exercised on third-party components, including open-source components, so that they do not compromise the product's security
- [ ] 13(6): a vulnerability found in a component is reported to its maintainer, remediated, and the fix shared, in a machine-readable format where appropriate
- [ ] 13(7): relevant cybersecurity aspects, including vulnerabilities and third-party information, are documented systematically and the risk assessment updated
- [ ] 13(8): vulnerabilities are handled per Annex I Part II for the support period; the support period is determined (at least five years unless expected use is shorter) and its basis recorded in the technical documentation
- [ ] 13(9): each security update remains available for at least 10 years after issue or the remaining support period
- [ ] 13(10): the latest-version rule is relied on only where users can upgrade free of charge without additional hardware or software costs
- [ ] 13(11): any public archive of earlier versions carries clear risk warnings
- [ ] 13(12): before placing on the market, the technical documentation is drawn up, the conformity assessment completed, the EU declaration of conformity drawn up and the CE marking affixed
- [ ] 13(13): the technical documentation and declaration are kept for 10 years after placing or the support period, whichever is longer
- [ ] 13(14): procedures keep series production in conformity, taking account of design changes and changes to harmonised standards and specifications
- [ ] 13(15): the product bears a type, batch or serial number or another identification element
- [ ] 13(16): the manufacturer's name, registered trade name or trademark, postal address, email or digital contact and website appear on the product, its packaging or an accompanying document, and in the Annex II information
- [ ] 13(17): a single point of contact lets users report and receive vulnerability information by their preferred means, not limited to automated tools, and is stated in the Annex II information
- [ ] 13(18): the Annex II information accompanies the product in paper or electronic form, is retained for 10 years or the support period, and online copies stay available
- [ ] 13(19): the end of the support period, at least month and year, is clearly shown at the time of purchase; users are notified of the end of support where feasible
- [ ] 13(20): the EU declaration of conformity, or the simplified declaration with the full declaration's internet address, accompanies the product
- [ ] 13(21): a known or suspected non-conformity is corrected immediately, or the product withdrawn or recalled, as appropriate

- [ ] 13(22): information and documentation demonstrating conformity is supplied to a market surveillance authority on reasoned request, in a language it easily understands, with cooperation on corrective measures
- [ ] 13(23): market surveillance authorities and, where feasible, users are informed before operations cease
- [ ] 13(24): the SBOM follows any Commission implementing act on format and elements (none adopted as of 30 Oct 2026; design to CycloneDX 1.6 or later or SPDX 3.0.1 or later)
- [ ] 13(25): SBOMs can be produced for a market surveillance request made for a Union-wide dependency assessment

5. Articles 14 to 16: reporting duties and platform readiness

Live since 11 Sep 2026 for every in-scope product, including those placed on the market earlier (Art 69(3)). Clocks run from awareness with a reasonable degree of certainty.

- [ ] 14(1): actively exploited vulnerabilities are notified (Art 3(42): reliable evidence of malicious exploitation without the owner's permission)
- [ ] 14(2)(a): early warning within 24 hours of awareness
- [ ] 14(2)(b): vulnerability notification within 72 hours: general information on the product, the exploit and the vulnerability, corrective or mitigating measures taken and available to users
- [ ] 14(2)(c): final report no later than 14 days after a corrective or mitigating measure is available: severity, impact, malicious actor where known, details of the fix
- [ ] 14(3): severe incidents having an impact on the security of the product are notified
- [ ] 14(4)(a): early warning within 24 hours, stating whether unlawful or malicious acts are suspected
- [ ] 14(4)(b): incident notification within 72 hours: nature of the incident, initial assessment, measures taken and available to users
- [ ] 14(4)(c): final report within one month of the 72-hour notification
- [ ] 14(5): the severe-incident criteria are written into the decision procedure: impact on the product's ability to protect sensitive or important data or functions, or malicious code executing in the product or in users' systems
- [ ] 14(6): intermediate status reports are supplied on the CSIRT's request
- [ ] 14(7): notifications are filed on the single reporting platform to the coordinator CSIRT of the main-establishment Member State; for a manufacturer with no EU establishment the authorised representative, importer, distributor or most-users fallback is decided in advance

- [ ] 14(8): impacted users and, where appropriate, all users are informed without undue delay about the vulnerability or incident and the corrective measures, in a structured machine-readable format where appropriate
- [ ] 14(9) and 16(2): the grounds in Delegated Regulation (EU) 2026/881 for a CSIRT to delay dissemination are understood; the particularly exceptional circumstances flag is used only where justified
- [ ] 14(10): notification templates follow any Commission implementing act on format and procedure (none adopted; the ENISA glossary fields are the de facto format)
- [ ] Art 15: the voluntary reporting route for other vulnerabilities, threats, incidents and near misses is known (not yet available on the platform)
- [ ] Art 16: the organisation is registered on the ENISA platform with a Primary and Secondary Assigned Representatives, EU Login with MFA, and the CSIRT association validated
- [ ] Awareness, escalation and submission timestamps are recorded in UTC and retained with the evidence for every stage
- [ ] Legacy and end-of-support products stay in the reportable inventory; reporting continues after the support period ends
- [ ] Importers and distributors have a channel to inform the manufacturer of vulnerabilities without undue delay (Arts 19(5), 20(4), from 11 Dec 2027)

6. Annex II: information and instructions to the user

Supplied with the product in paper or electronic form, in a language users and authorities understand, and kept available for 10 years or the support period (Art 13(18)).

- [ ] Point 1: manufacturer's name, registered trade name or trademark, postal address, email or other digital contact, and website where available
- [ ] Point 2: the single point of contact for reporting and receiving vulnerability information, and where the coordinated vulnerability disclosure policy can be found
- [ ] Point 3: name and type of the product and any additional information enabling its unique identification
- [ ] Point 4: intended purpose, including the security environment provided by the manufacturer, essential functionalities and information about the security properties
- [ ] Point 5: any known or foreseeable circumstance of use or misuse that may lead to significant cybersecurity risks
- [ ] Point 6: where applicable, the internet address of the EU declaration of conformity
- [ ] Point 7: the type of technical security support offered and the end date of the support period

- [ ] Point 8(a): the measures to take at initial commissioning and throughout the lifetime to ensure secure use
- [ ] Point 8(b): how changes to the product can affect the security of data
- [ ] Point 8(c): how security-relevant updates can be installed
- [ ] Point 8(d): secure decommissioning, including how to remove user data securely
- [ ] Point 8(e): how the default automatic installation of security updates can be turned off
- [ ] Point 8(f): for a product intended for integration into other products, the information integrators need to comply with Annex I and the Annex VII documentation requirements
- [ ] Point 9: where the manufacturer chooses to make the SBOM available to users, where it can be accessed
- [ ] Cross-check: the end of support (month and year) is visible at the time of purchase, not only in the documentation (Art 13(19))

7. Technical documentation, declaration and CE marking

Drawn up before placing on the market, kept current through the support period, and held for 10 years or the support period, whichever is longer (Arts 13(12)-(13), 31).

Annex VII technical documentation

- [ ] Point 1: general description, including intended purpose, software versions affecting compliance, photographs or illustrations of hardware, and the Annex II user information
- [ ] Point 2(a): design and development information, including drawings and a system architecture description showing how software components build on or feed into each other
- [ ] Point 2(b): vulnerability-handling information: the SBOM, the coordinated vulnerability disclosure policy, evidence of the contact address for reporting, and the technical description of the secure update mechanism
- [ ] Point 2(c): production and monitoring processes and their validation
- [ ] Point 3: the Art 13 cybersecurity risk assessment, including how each Annex I Part I requirement applies and the justification for any not applied
- [ ] Point 4: the information used to determine the support period (Art 13(8))
- [ ] Point 5: the harmonised standards, common specifications or certification schemes applied in full or in part, and the solutions adopted where none applied
- [ ] Point 6: test reports on the product and on the vulnerability-handling processes against Annex I Parts I and II
- [ ] Point 7: a copy of the EU declaration of conformity
- [ ] Point 8: the SBOM, available for a market surveillance authority's reasoned request

- [ ] The file exists per product version, is retrievable outside engineering tooling, and can be supplied in a language the authority understands (Art 13(22))

Annex V EU declaration of conformity (Art 28)

- [ ] Point 1: name and type of the product and information enabling unique identification
- [ ] Point 2: name and address of the manufacturer or its authorised representative
- [ ] Point 3: statement that the declaration is issued under the sole responsibility of the manufacturer
- [ ] Point 4: object of the declaration, with enough detail for traceability, optionally with a photograph
- [ ] Point 5: statement of conformity with the relevant Union harmonisation legislation
- [ ] Point 6: references to the harmonised standards, common specifications or certifications used
- [ ] Point 7: where applicable, the notified body's name and number, the procedure performed and the certificate reference
- [ ] Point 8: additional information; signed for and on behalf of the manufacturer with place, date, name and function
- [ ] One declaration per product, updated as appropriate, in the languages required by the Member States of sale (Art 28); a simplified Annex VI declaration gives the exact internet address of the full one (Art 13(20))

CE marking (Arts 29 to 31)

- [ ] Affixed visibly, legibly and indelibly before placing on the market, on the product, or else on the packaging and the declaration (Art 30(1))
- [ ] For software, placed on the EU declaration of conformity or on the accompanying website in a section consumers can reach directly (Art 30(1))
- [ ] Followed by the notified body's identification number where Module H was used (Art 30(4))
- [ ] Not affixed before the conformity assessment is complete; no marking or sign likely to mislead third parties as to its meaning (Art 29)

8. Annex VIII: conformity assessment modules

The route recorded in checklist 1 decides which block applies (Art 32). As of 30 Oct 2026 no harmonised standard is cited and no notified body is designated, so Class I products need Module B+C or H in practice.

Module A, internal control (default products; Class I only with a fully applied cited standard; Art 32(5) open-source products with public documentation)

- [ ] Annex VII technical documentation complete
- [ ] Internal measures ensure design, development, production and vulnerability handling conform to Annex I
- [ ] EU declaration of conformity drawn up on the manufacturer's sole responsibility; CE marking affixed
- [ ] Documentation and declaration retained for 10 years or the support period

Module B, EU-type examination

- [ ] Application lodged with one notified body, with the technical documentation, the risk assessment and supporting evidence
- [ ] Design and vulnerability-handling processes examined and specimens tested by the body; EU-type examination certificate obtained with its stated validity
- [ ] The body is informed of every modification that may affect conformity (point 7)
- [ ] Periodic audits of vulnerability handling by the body accepted (point 8)
- [ ] Certificate and its additions retained for 10 years or the support period (point 10)

Module C, conformity to type

- [ ] Production keeps each unit in conformity with the approved type and the Part II processes
- [ ] EU declaration of conformity drawn up per product model; CE marking affixed

Module H, full quality assurance

- [ ] An approved quality system covers design, development, final inspection, testing and vulnerability handling (point 3.2)
- [ ] Intended changes to the quality system notified to the notified body (point 3.5)
- [ ] Periodic audits and site access for the body accepted (point 4); one model's technical documentation per product category available for review
- [ ] Quality-system documentation, approved changes and body decisions retained for 10 years or the support period (point 6)
- [ ] CE marking followed by the notified body's identification number (point 5.1; Art 30(4))

All routes

- [ ] A substantial modification is treated as a new placing on the market: the modified parts are re-assessed and the body informed where Module B or H applies (guidance pts 104-124)
- [ ] Where a European cybersecurity certificate is relied on, it covers the requirements concerned and the Art 27(9) delegated act recognising the scheme is in force (none adopted as of 30 Oct 2026)

9. Other economic operators

All apply from 11 Dec 2027. An importer or distributor that rebrands or substantially modifies a product moves to checklists 4 to 8 as its manufacturer (Art 21).

Authorised representative (Art 18, optional)

- [ ] A written mandate exists and covers only delegable tasks; it does not cover Art 13(1)-(11), the first subparagraph of Art 13(12) or Art 13(14) (Art 18(2))
- [ ] The EU declaration of conformity and technical documentation are held for 10 years or the support period and supplied to authorities on reasoned request (Art 18(3))
- [ ] Cooperation with market surveillance authorities on any action to eliminate risks (Art 18(3))

Importer (Art 19)

- [ ] 19(1): only products that comply with Annex I and whose manufacturer's processes meet Part II are placed on the market
- [ ] 19(2): verified before placing: the conformity assessment was carried out, the technical documentation exists, the CE marking is affixed, the declaration and Annex II information accompany the product, and the manufacturer's identification under Art 13(15)-(16) is present
- [ ] 19(3): a non-conforming product, or one presenting a significant cybersecurity risk, is not placed; the manufacturer and the market surveillance authorities are informed
- [ ] 19(4): the importer's name, registered trade name or trademark, postal address, contact and website appear on the product, its packaging or an accompanying document, in the Annex II information
- [ ] 19(5): the manufacturer is informed of vulnerabilities without undue delay; authorities are informed immediately where there is a significant risk
- [ ] 19(6)-(8): a copy of the declaration is kept for 10 years or the support period; information and cooperation are supplied on reasoned request
- [ ] 19(9): authorities and users are informed if the manufacturer has ceased operations and cannot meet its obligations

Distributor (Art 20)

- [ ] 20(1): due care in relation to the requirements of the Regulation
- [ ] 20(2): verified before making available: the CE marking is present and the manufacturer and importer have met Art 13(15), (16), (18), (19), (20) and Art 19(4)
- [ ] 20(3): a product believed non-conforming is not made available; where it presents a significant risk, the manufacturer or importer and the authorities are informed

- [ ] 20(4): the manufacturer or importer is informed of vulnerabilities without undue delay; authorities where there is a significant risk
- [ ] 20(5)-(6): information and cooperation on reasoned request; authorities and users informed if the manufacturer has ceased operations

Open-source software steward (Art 24)

- [ ] 24(1): a documented, verifiable cybersecurity policy fosters secure development and effective vulnerability handling, covers vulnerability documentation and remediation, information sharing with the community and promotion of voluntary reporting
- [ ] 24(2): cooperation with market surveillance authorities; the policy is supplied on reasoned request in a language they understand
- [ ] 24(3): Art 14(1), (3) and (8) reporting is performed to the extent the steward is involved in development or runs the development infrastructure
- [ ] Steward status is recorded per project, and any monetisation that would make the steward a manufacturer is flagged

10. Transition, traceability and watch items

- [ ] Art 23: the name and address of every operator that supplied you, and where available every operator you supplied, are recorded and kept for 10 years after each supply
- [ ] Art 69(1): existing EU type-examination certificates and approval decisions under other Union law are relied on only for the risks they cover and only until 11 Jun 2028
- [ ] Art 69(2): every unit placed on the market on or after 11 Dec 2027, including units of designs that shipped earlier, is assessed, declared and CE-marked
- [ ] Art 69(3): all products placed before 11 Dec 2027 are covered by the Art 14 reporting process
- [ ] Art 71: the programme plan carries the three application dates: 11 Jun 2026 notified bodies, 11 Sep 2026 reporting, 11 Dec 2027 everything else
- [ ] Guidance C(2026) 5252 and FAQ v1.4 versions in use are recorded, and decisions resting on them are marked as reliance on non-binding guidance
- [ ] A standards watch re-maps the Annex I evidence when prEN 40000-1-3 and EN 40000-1-4 are cited in the Official Journal, and re-opens Module A for Class I products at that point
- [ ] The notified-body watch tracks NANDO designations and the Art 27(9) EUCC delegated act (planned Q4 2026)
- [ ] The Member State watch tracks national enforcement acts and the designated market surveillance authority for each market sold into

- [ ] For UK-based manufacturers: the importer or responsible-operator arrangement for direct-to-consumer EU sales, the coordinator CSIRT under Art 14(7), and the Northern Ireland status are reviewed quarterly